

Buyer Arena: preparado para lanzar

40 participantes sintéticos en 5 paneles · profundidad estándar · 1 min

Instalación y compilación ejecutadas

<https://abrahamhl.github.io/buyer-arena-site/es/>

Preparación para el lanzamiento



Preparación para el lanzamiento

★★★★★ 5.0 /5



40%

Usuarios finales

¿Llegan los clientes al objetivo, y dónde se pierden?

100/100

★★★★★



15%

Desarrolladores

¿Puede alguien que desarrolla ponerlo en marcha desde el README?

100/100

★★★★★



15%

Inversores

¿Qué puede verificar un inversor sobre el valor y el modelo de negocio?

83/100

★★★★★



15%

Equipo rojo

¿Cuán expuesto está, también frente a agentes de IA?

94/100

★★★★★



15%

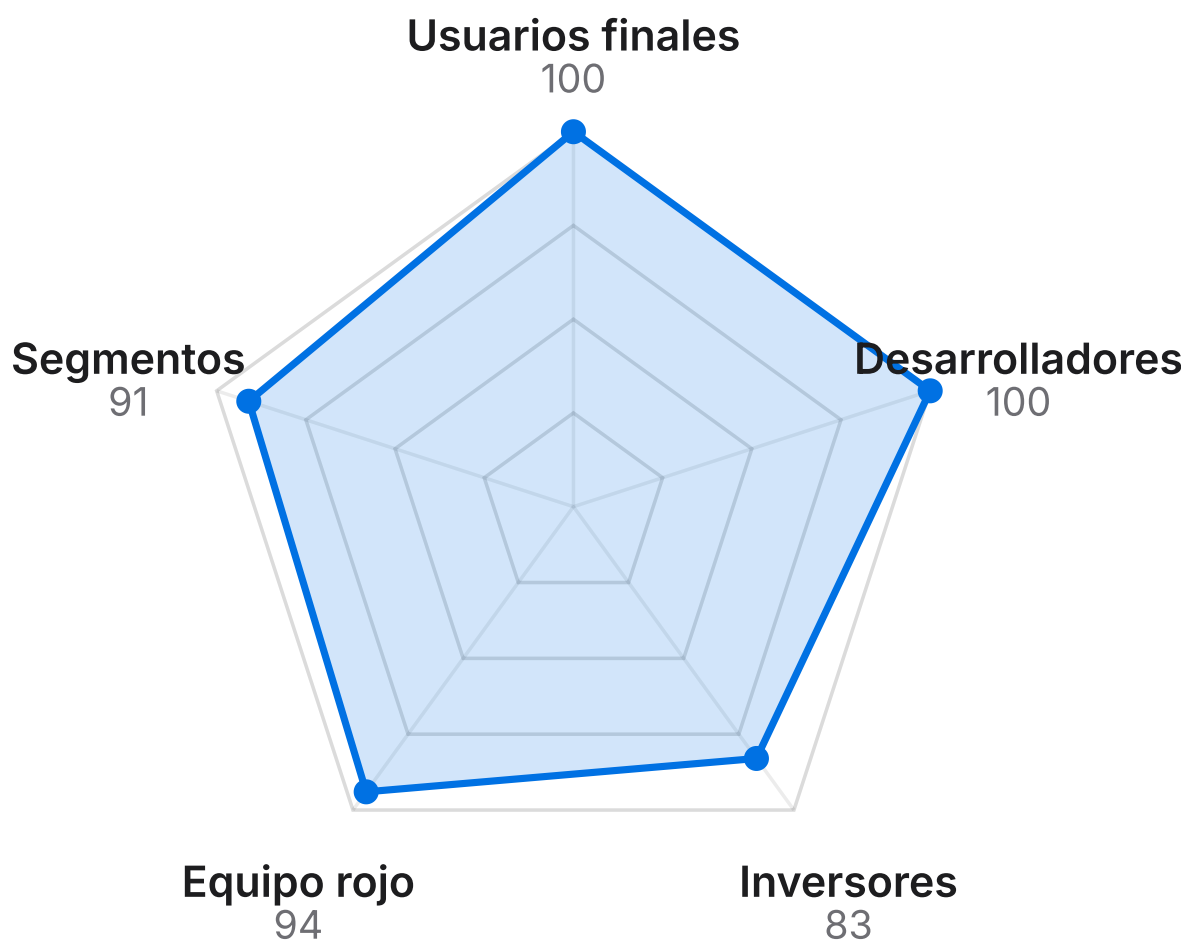
Segmentos

¿Funciona para todo el mundo, no solo para la visita media?

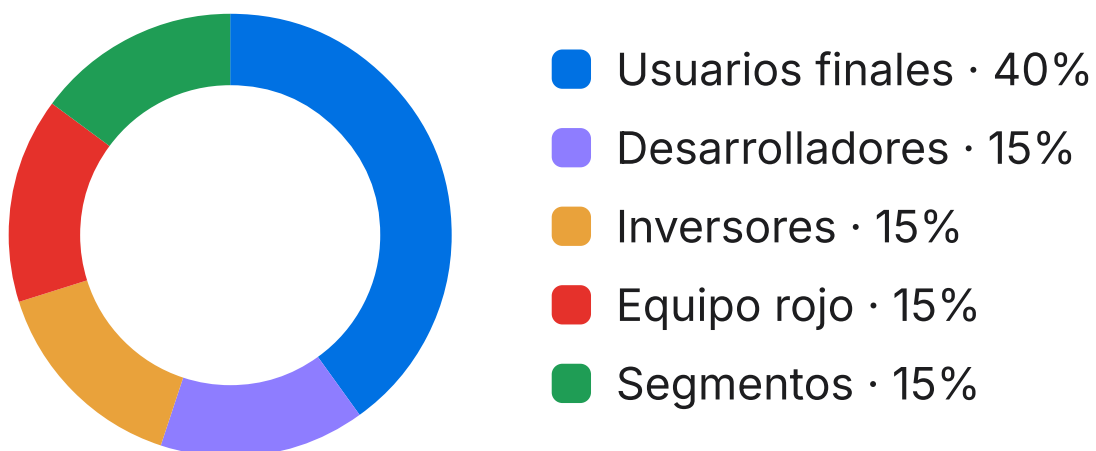
91/100

★★★★★

Puntuación por panel



Reparto de la atención



Prometido frente a construido

100%

29 hechos · 0 parciales · 0 pendientes

- El repositorio se instala `package-lock.json`
- La demo arranca con un comando `package.json`
- 20 compradores sintéticos pueden ejecutarse `src/workflow.ts:94`
- Existen 5 arquetipos `src/personas/templates.ts:57`
- Existen historias de cliente `src/stories/story.ts`
- Se capturan recorridos reales de navegador `src/simulator/journey.ts`
- La evidencia se guarda y cada hallazgo la cita `src/auditors/consensus.ts:82`
- Funciona la comparación actual vs candidata `src/comparison/compare.ts`
- Análisis de cinco auditores `src/auditors/rules.ts:254`
- Se genera ROI_BACKLOG.md `examples/demo-output/ROI_BACKLOG.md`
- Funciona el informe HTML `src/reports/html.ts`
- Reproducción y trazas inspeccionables `src/cli/main.ts:480`
- Servidor MCP funcional `src/mcp/server.ts`
- Tests y demo sin API de pago `vitest.config.ts:10`

Acciones prioritarias

Plan de acción →

- 1 Evidencia de adopción**
Consigue usuarios reales antes de buscar inversión: publica una versión, lista quién lo usa y reúne dos o tres testimonios.
Inversores · puntuación 5 · impacto 57
- 2 Accesibilidad**
Etiqueta cada campo, añade texto alternativo, agranda los objetivos pequeños y corrige el contraste.
Segmentos · puntuación 66 · impacto 20
- 3 Superficie web (Argus)**
Añade cabeceras de seguridad, redirecciones HTTPS y páginas de privacidad accesibles.
Equipo rojo · puntuación 71 · impacto 13

Usuarios finales

¿Llegan los clientes al objetivo, y dónde se pierden?

100/100



40 % de la ejecución

Bien

Objetivo alcanzado



100%

El 100% de 16 compradores sintéticos alcanzó el objetivo.

Qué hacer: Empieza por la principal fricción de la pestaña Usuarios finales.

Evidencia

`current-p-001:e0` — Budget freelancer · completed

`current-p-002:e0` — Agency operator · completed

`current-p-003:e0` — Non-technical owner · completed

Bien

El precio se encuentra



100%

El 100% vio un precio.

Qué hacer: Pon los precios en el menú y junto al botón principal.

Bien

Forma clara de empezar



100%

El 100% encontró cómo empezar.

Qué hacer: Usa un único botón principal explícito en la primera pantalla.

Bien

Sin errores del navegador



100%

El 0% de los recorridos tuvo un error de JavaScript o de red.

Qué hacer: Corrige los errores listados en Ingeniería, en la pestaña Usuarios finales.

Bien

Poca fricción



100%

0.00 eventos de fricción por comprador.

Qué hacer: Elimina bucles, pop-ups y rechazos de formularios.

Bien

Camino corto hasta el objetivo



100%

Mediana de 1 pasos hasta el objetivo.

Qué hacer: Quita páginas y campos entre la llegada y el primer valor.

El 100 % de los compradores sintéticos alcanzó el objetivo.

16 compradores · 5 segmentos · 1 versiones, probados en un navegador real.

• Indicador de conversión



```
buyer-arena - zsh
$ buyer-arena run --size 16 --seed 42
✓ 16 recorridos · 16 alcanzaron el objetivo
```

Objetivo alcanzado



100 %

Abandono



0 %

En pocas palabras

1 Qué ha pasado

Enviamos 16 clientes sintéticos. El 100 % alcanzó el objetivo.

2 Por qué

Ningún obstáculo hizo que se fueran varios clientes.

3 Qué hacer ahora

Prueba con una población mayor (--size 100) para encontrar problemas menos frecuentes.

Son clientes simulados. Confirma las decisiones importantes con un test A/B real.

Embudo

Llegó		100 %
Vio un precio		100 %
Encontró cómo empezar		100 %
Empezó el registro		100 %
Llegó al pago		100 %
Alcanzó el objetivo		100 %

Proporción de compradores que llegó a cada etapa o a una posterior.

Segmentos

Segmento	n	current
 Freelance con presupuesto ajustado sensible al precio	4	100 %
 Responsable de agencia orientado al objetivo	3	100 %
 Negocio sin perfil técnico principiante	3	100 %
 Profesional de oficio en movimiento móvil y con prisa	3	100 %
 Responsable de finanzas prudente escéptico	3	100 %

Dónde se atascan los compradores

Cada punto cita los eventos exactos que lo demuestran. Pulsa uno para ver a ese comprador.

No se detectaron señales de fricción.

Experimentos recomendados

Ordenados por objetivo recuperable, ponderado por confianza, por unidad de esfuerzo.

No hay fricción accionable con evidencia.

Recorridos

Cada comprador sintético, paso a paso, con capturas.

Todos

Se detuvieron

Completaron



Mei C.

Freelance con presupuesto ajustado

C ✓ 1



Kenji A.

Responsable de agencia

C ✓ 1



Kenji V.

Negocio sin perfil técnico

C ✓ 1



Marta D.

Profesional de oficio en movimiento

C ✓ 1



Ingrid R.

Responsable de finanzas prudente

C ✓ 1



Mei C.

current

Freelance con presupuesto ajustado

Ordenador · 1366×768

17 EUR/mes

Mei trabaja por cuenta propia en diseño. Ahora mismo, Mei hace las facturas a mano en una hoja de cálculo. Antecedentes: Mei usa hojas de cálculo gratuitas; y canceló una herramienta tras una subida de precio inesperada. Mei puede gastar hasta 17 EUR al mes y se defiende con la mayoría de las webs. Mei encuentra esta herramienta de facturación porque alguien de confianza le habló de esta herramienta, y tiene la tarde para mirarlo con calma. Mei desconfía de los precios que no se muestran desde el principio, y no pagará más de su presupuesto mensual.

✓ Completado en 1 pasos



Abre

/buyer-arena-site/es/ ^{e0}

Hito

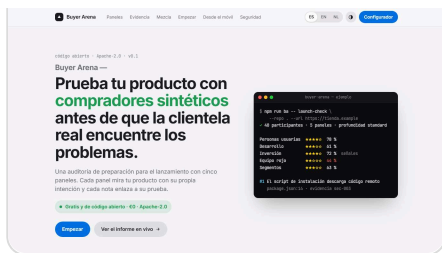
Llegó ^{e1}



... /buyer-arena-site/es/

Hito

Vio un precio ^{e3}



Hito

Alcanzó el objetivo e4

Objetivo alcanzado

Objetivo alcanzado e5

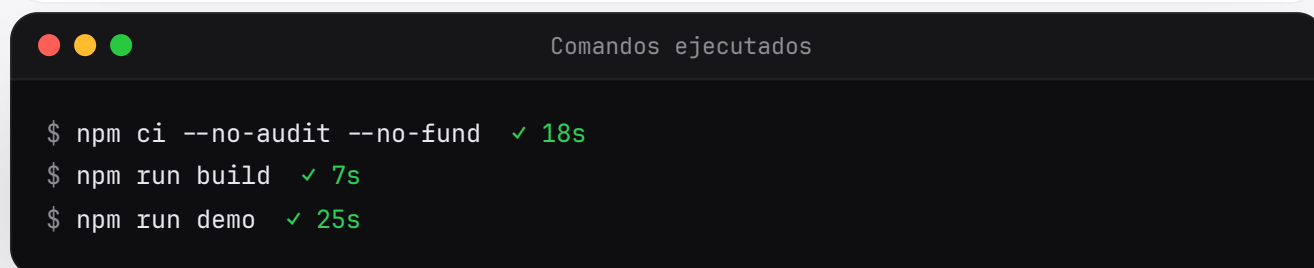
Desarrolladores

¿Puede alguien que desarrolla ponerlo en marcha desde el README?

100/100



15 % de la ejecución · 6 revisores sintéticos



Comprobaciones

README que explica y guía		100%
Los comandos de inicio rápi...		100%
Los requisitos están indica...		100%
El CI ejecuta los tests		100%
Hay tests automáticos		100%
Documentación para colaborar		100%
Licencia clara		100%
Herramientas de calidad		100%
La instalación limpia funci...		100%
La compilación funciona		100%
Tiempo hasta el primer éxito		100%

6 revisores sintéticos

Recién Llegado		100%
Colaborador		100%
Integrador		100%

Bien

README que explica y guía

★★★★★

100%

14 encabezados; se revisan título, instalación/inicio rápido, uso y una captura.

Qué hacer: Añade una sección de inicio rápido con los comandos exactos y una captura del resultado.

Evidencia

`README.md:1` — `<div align="center">`

Bien

Los comandos de inicio rápido funcionan

★★★★★

100%

18 comandos de shell en el README; 0 apuntan a scripts npm que no existen.

Qué hacer: Haz que cada comando del README corresponda a un script real, en el orden en que se ejecutan.

Evidencia

`README.md:21` — `git clone https://github.com/abrahamhl/buyer-arena.git && cd buyer-arena`

`README.md:22` — `npm install`

`README.md:23` — `npm run demo`

Bien

Los requisitos están indicados

★★★★★

100%

Versión declarada en package.json: `>=22.12`. Se revisan el README y `.nvmrc`.

Qué hacer: Indica la versión en el README, en engines de package.json y en `.nvmrc`.

Evidencia

`README.md:26` — The first run downloads Playwright's Chromium once (about 150 MB). You need Node 22.12 or newer.

`package.json` — `engines.node: >=22.12`

Bien

El CI ejecuta los tests

★★★★★

100%

2 workflows; se comprueba que alguno ejecute los tests.

Qué hacer: Añade un workflow de CI que instale y ejecute los tests en cada push.

Evidencia

`.github/workflows/ci.yml:32` — `- run: npm test`

Bien

Hay tests automáticos

★★★★★

100%

11 archivos de test.

Qué hacer: Cubre el camino principal con tests automáticos antes de invitar a colaborar.

Evidencia

```
tests/fixtures/fake-engine.mjs
tests/helpers.ts
tests/integration/cli-mcp.test.ts
tests/integration/guarantees.test.ts
tests/integration/journeys.test.ts
```

Bien

Documentación para colaborar

★★★★★

100%

4 de CONTRIBUTING, CHANGELOG, SECURITY y CODE_OF_CONDUCT.

Qué hacer: Añade CONTRIBUTING, SECURITY y un CHANGELOG.

Evidencia

```
CONTRIBUTING.md
CHANGELOG.md
SECURITY.md
CODE_OF_CONDUCT.md
```

Bien

Licencia clara

★★★★★

100%

Licencia detectada: Apache License.

Qué hacer: Añade una licencia estándar (Apache-2.0 o MIT para la adopción).

Evidencia

```
LICENSE:1 — Apache License
```

Bien

Herramientas de calidad

★★★★★

100%

3 configuraciones (tipos, lint, formato) y carpeta de ejemplos.

Qué hacer: Activa tipos estrictos, un linter y un formateador, e incluye ejemplos.

Evidencia

```
tsconfig.json
eslint.config.js
.prettierrc.json
```

Bien

La instalación limpia funciona



100%

Instalado desde cero en una copia desechable en 18 s.

Qué hacer: Haz que una instalación limpia funcione solo con el lockfile (npm ci).

Evidencia

```
npm ci --no-audit --no-fund — 18 s
```

Bien

La compilación funciona



100%

Compilado en 7 s.

Qué hacer: Arregla la compilación para que funcione en una máquina limpia.

Evidencia

```
npm run build — 7 s
```

Bien

Tiempo hasta el primer éxito



100%

Primer comando del README tras instalar: npm run demo (25 s).

Qué hacer: Ofrece un comando que muestre un resultado real en menos de un minuto.

Evidencia

```
npm run demo — 25 s
```

Inversores

¿Qué puede verificar un inversor sobre el valor y el modelo de negocio?

83/100



15 % de la ejecución · 6 revisores sintéticos

Modelo de negocio con más respaldo

Open core

Núcleo gratuito para la adopción; de pago las ejecuciones alojadas, las funciones de equipo y los controles empresariales.

licencia permisiva

menciona funciones empresariales

menciona una oferta alojada

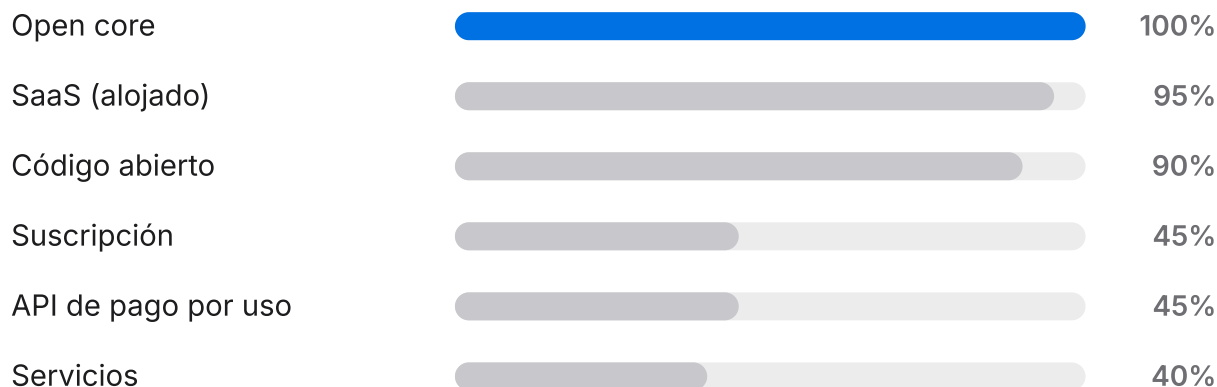
estrategia de licencia o negocio escrita

Segunda opción: SaaS (alojado). Son señales del repositorio, no una predicción de inversión.



Potencial de viralidad

Encaje de modelos de negocio



A quién más podría interesar



Potencial de viralidad

100/100

✓ Demo con un solo comando +20

✓ Resultado visual en el README +20

✓ Aprovecha la tendencia de agentes de IA +20

✓ Licencia permisiva +15

✓ Promesa clara en una línea +10

✓ Primer éxito rápido +15

Comprobaciones

Problema y promesa claros		100%
Diferenciación explícita		85%
Demo y prueba visual		100%
Modelo de negocio articulado		100%
La licencia encaja con el m...		95%
Prueba de ejecución		92%
Evidencia de adopción		5%
Defensibilidad		100%
Mercado objetivo claro		90%
Límites y riesgos honestos		100%
Gobernanza de código abierto		100%

6 revisores sintéticos

Business angel		97%
Fondo semilla		79%
Comprador estratégico / lab...		77%
Fundación de código abierto		97%

Bien

Problema y promesa claros

★★★★★ 100%

Se revisó la primera pantalla del README: promesa en una línea y un «por qué».

Qué hacer: Abre el README con una frase de valor y una sección breve de «Por qué».

Evidencia

`README.md:1` — `**Test your product with synthetic buyers before real customers find the problems.**`

Bien

Diferenciación explícita

★★★★★ 85%

Se buscó una comparación con las alternativas.

Qué hacer: Añade una tabla «frente a las alternativas» con lo que solo haces tú.

Evidencia

`README.md:35` — `**The report is a small app in its own right.** It is available in ES · EN · NL; every text switches, including buyer thoughts, findings and customer stories.`
|

`README.md:69` — `## Why`

`README.md:74` — `| | Opinion-poll personas | **Buyer Arena** |`

Bien

Demo y prueba visual

★★★★★ 100%

Demo de un comando, capturas y primer éxito medido (25 s).

Qué hacer: Muestra una demo de un comando y una captura o GIF en la primera pantalla.

Evidencia

`README.md:23` — `npm run demo # 20 buyers × 2 versions of a demo SaaS · 15–30 s · no API keys`

`README.md:90` — `npm run demo # bundled demo, fully offline`

`README.md:28` — `![Buyer Arena report — light theme, Simple mode]`
(assets/demo/report-hero.png)

`README.md:31` — `<td width="62%"></td>`

`README.md:32` — `<td></td>`

Bien

Modelo de negocio articulado

★★★★★ 100%

4 de 4 señales: precios, oferta alojada, funciones empresariales y estrategia escrita.

Qué hacer: Escribe quién paga, por qué y cómo la parte gratuita lleva hasta ahí.

Evidencia

`LICENSE_STRATEGY.md`

`src/providers/pricing.ts`

`LICENSE_STRATEGY.md:4` — licensed hosted and enterprise layer, not from restricting the core. The name and logo are

`LICENSE_STRATEGY.md:10` — 2. ****Commercial opportunity.**** Hosted runs, team dashboards, CI integrations, calibration against private analytics, and enterprise controls such as SSO and aud

`LICENSE_STRATEGY.md:11` — 3. ****Protection against direct hosted cloning.**** Stop a third party from offering "Buyer Arena as a service" built on our work without giving anything back.

`LICENSE_STRATEGY.md:19` — | AGPL-3.0 | Medium to low; many companies ban it outright | Strong: host

`LICENSE_STRATEGY.md:4` — licensed hosted and enterprise layer, not from restricting the core. The name and logo are

`LICENSE_STRATEGY.md:10` — 2. ****Commercial opportunity.**** Hosted runs, team dashboards, CI integrations, calibration against private analytics, and enterprise controls such as SSO and aud

Bien

La licencia encaja con el modelo

★★★★★

95%

Licencia comparada con las señales de monetización encontradas.

Qué hacer: Elige una licencia que sirva a la adopción y mantenga aparte la capa de pago.

Evidencia

`LICENSE:1` — Apache License

`LICENSE:178` — APPENDIX: How to apply the Apache License to your work.

`LICENSE_STRATEGY.md:19` — | AGPL-3.0 | Medium to low; many companies ban it outright | Strong: host

Bien

Prueba de ejecución

★★★★★

92%

11 archivos de test, 12 commits, CI y changelog.

Qué hacer: Muestra ejecución constante: tests, CI, versiones y changelog.

Evidencia

`tests` — 11 test files

`ci` — 2 workflows

`git` — 12 commits

Falla

Evidencia de adopción

★☆☆☆☆

5%

0 versiones publicadas, 2 contribuidores; usuarios o testimonios: 0.

Qué hacer: Consigue usuarios reales antes de buscar inversión: publica una versión, lista quién lo usa y reúne dos o tres testimonios.

Evidencia

`git tags` — 0 releases/tags

`git authors` — 2 commit authors

`adopters` — no adopters, users or testimonials

Bien

Defensibilidad

★★★★★ 100%

Se buscaron ventajas de datos, alojamiento o empresa difíciles de copiar.

Qué hacer: Explica qué mejora con el uso (datos, calibración, integraciones).

Evidencia

`LICENSE_STRATEGY.md:10` — 2. **Commercial opportunity.** Hosted runs, team dashboards, CI integrations, calibration against private analytics, and enterprise controls such as SSO and aud

`LICENSE_STRATEGY.md:26` — - A hosted clone would need the parts that do not live in this repo: managed browser fleets, secure credential handling for customer staging environments, calib

`README.md:119` — | `calibrate <aggregates>` | Simulated funnel vs. **aggregate** real funnel, per-stage error |

`README.md:263` — - Calibration accepts **aggregates only**: shares and rates, with a minimum group size of 10 or more. The schema has no field that could hold a person-level rec

`LICENSE_STRATEGY.md:4` — licensed hosted and enterprise layer, not from restricting the core. The name and logo are

`LICENSE_STRATEGY.md:10` — 2. **Commercial opportunity.** Hosted runs, team dashboards, CI integrations, calibration against private analytics, and enterprise controls such as SSO and aud

`LICENSE_STRATEGY.md:11` — 3. **Protection against direct hosted cloning.** Stop a third party from offering "Buyer Arena as a service" built on our work without giving anything back.

`LICENSE_STRATEGY.md:19` — | AGPL-3.0 | Medium to low; many companies ban it outright | Strong: host

Bien

Mercado objetivo claro

★★★★★ 90%

Para quién es: equipos, desarrollo, consumidores, agentes de IA.

Qué hacer: Nombra el primer segmento de clientes y el trabajo por el que te paga.

Evidencia

`README.md:11` — `[!CI](https://img.shields.io/badge/CI-GitHub_Actions-2d5bff)]`

(.github/workflows/ci.yml)

README.md:80 — | Output for the team | A summary | A ranked `ROI\_BACKLOG.md` with a visible scoring formula |

README.md:133 — | **Red team** | Secrets, supply chain, CI injection, prompt injection in files agents read, MCP tool risks, privacy; risk index and AI-agent risk |

README.md:22 — npm install # also builds the CLI

README.md:23 — npm run demo # 20 buyers × 2 versions of a demo SaaS · 15–30 s · no API keys

README.md:95 — `npm run ba -- <command>` runs the local CLI. `npm link` puts a `buyer-arena` command on your

README.md:96 — PATH, which the examples below use. Do **not** run `npx buyer-arena` until the package is

README.md:116 — | `report` / `audit` | Re-analyse a session; `audit --auditor anthropic: <model>` uses LLM auditors |

Bien

Límites y riesgos honestos

★★★★★ 100%

Se buscaron limitaciones declaradas y una política de seguridad.

Qué hacer: Declara las limitaciones con claridad; la honestidad genera confianza.

Evidencia

CONTRIBUTING.md:29 — 5. **Honest statistics.** Synthetic results are a conversion proxy. Small samples are labelled EXPLORATORY SIGNAL.

README.md:39 — BASELINE → CANDIDATE EXPLORATORY SIGNAL CONVERSION PROXY

README.md:213 — - Below 30 pairs every result is labelled **EXPLORATORY SIGNAL**. Buyer Arena never uses the word "significant".

README.md:214 — - Goal completion is a **CONVERSION PROXY**, not predicted revenue. The ROI backlog is a unitless leverage score: `frequency × severity × goal impact × breadth`

SECURITY.md

Bien

Gobernanza de código abierto

★★★★★ 100%

Se revisaron CONTRIBUTING, CODE_OF_CONDUCT, SECURITY y TRADEMARKS.

Qué hacer: Añade archivos de gobernanza para que las empresas puedan adoptar y colaborar con seguridad.

Evidencia

CONTRIBUTING.md

CODE_OF_CONDUCT.md

SECURITY.md

Equipo rojo

¿Cuán expuesto está, también frente a agentes de IA?

94/100



15 % de la ejecución · 6 revisores sintéticos



6

Índice de riesgo

Riesgo bajo



5

Riesgo ante agentes de IA

Skills, herramientas MCP, prompt injection y entradas al modelo.

Por qué importan los agentes de IA

Los agentes ya leen tu documentación y tus skills y llaman a tus herramientas. Una instrucción escondida en un README, la descripción envenenada de una herramienta MCP o contenido web que llega a un modelo pueden hacer que un agente actúe contra quien lo usa. Estas comprobaciones buscan justo eso.

Modelo de amenazas

Vector de ataque	Estado	Evidencia
Secretos filtrados Claves de API, tokens o claves privadas subidas al repositorio.	Limpio	0
Dependencias vulnerables Vulnerabilidades críticas o altas conocidas en dependencias de producción.	Limpio	0
Código al instalar Scripts que se ejecutan solos al hacer npm install.	Limpio	0
Inyección en el CI Entradas del workflow o datos de PR interpolados en comandos de shell.	Limpio	0
Prompt injection en archivos que leen los agentes Instrucciones o Unicode oculto en skills, AGENTS.md, prompts o documentación que leen los agentes.	Limpio	0
Herramientas MCP con demasiado poder Herramientas MCP que pueden ejecutar shell, escribir archivos o salir a la red.	Limpio	0
Envenenamiento de herramientas MCP Descripciones de herramientas que cuelan instrucciones al modelo.	Limpio	0
Permisos de agente demasiado amplios Autoaprobación, consejos de «saltar permisos» o instalaciones curl sh.	Limpio	0
Contenido web no fiable → modelo El texto de una página llega a un modelo; su respuesta debe validarse antes de actuar.	Mitigado	3
Superficie web (Argus) Cabeceras de seguridad, HTTPS, páginas de privacidad y enlaces rotos del sitio público.	Detectado	4
Rastreo de terceros Páginas que llaman a servidores de terceros o crean cookies.	Limpio	0

Comprobaciones

Sin secretos en el reposito...		100%
Sin dependencias vulnerable...		100%
No se ejecuta código al ins...		100%
CI reforzado		100%
Sin prompt injection en arc...		100%
Herramientas MCP con mínimo...		100%
Sin permisos de agente dema...		100%
La salida del modelo se val...		80%
Ejecución de shell limitada		76%
Superficie web (Argus)		71%
Privacidad: cookies y terce...		100%

6 revisores sintéticos

Seguridad de aplicaciones		91%
Cadena de suministro		100%
Especialista en agentes de ...		91%
Privacidad y legal		92%

Bien**Sin secretos en el repositorio**

★★★★★

100%

0 posibles secretos (valores enmascarados).

Qué hacer: Revoca cualquier clave expuesta, bórrala del historial y añade escaneo de secretos al CI.

Bien**Sin dependencias vulnerables conocidas**

★★★★★

100%

npm audit: 0 críticas y 0 altas en dependencias de producción.

Qué hacer: Actualiza o sustituye los paquetes vulnerables.

Evidencia

```
npm audit --omit=dev —  
{"info":0,"low":0,"moderate":0,"high":0,"critical":0,"total":0}
```

Bien**No se ejecuta código al instalar**

★★★★★

100%

0 hooks de instalación (preinstall/install/postinstall).

Qué hacer: Evita los hooks de instalación; pasa la configuración a un comando explícito.

Bien**CI reforzado**

★★★★★

100%

0 posibles inyecciones; 0 acciones fijadas por etiqueta y no por commit.

Qué hacer: Pasa las entradas por variables de entorno, declara permisos mínimos y fija las acciones.

Bien**Sin prompt injection en archivos que leen los agentes**

★★★★★

100%

18 archivos legibles por agentes; 0 instrucciones sospechosas o caracteres ocultos.

Qué hacer: Elimina el Unicode oculto y las instrucciones dirigidas a la IA de documentación, skills y prompts.

Bien**Herramientas MCP con mínimo privilegio**

★★★★★

100%

8 herramientas MCP; 0 capacidades peligrosas; 10 protecciones (validación, listas permitidas).

Qué hacer: Dale a cada herramienta MCP entradas acotadas, listas permitidas y nada de shell; descripciones sin instrucciones.

Evidencia

```
src/mcp/server.ts:12 — assertTarget,  
src/mcp/server.ts:25 — const localOnly = () =>  
process.env.BUYER_ARENA_ALLOW_REMOTE !== '1';  
src/mcp/server.ts:34 — success_text: z.string().optional().describe('Regex: goal  
reached when page text matches'),  
src/mcp/server.ts:105 — server.registerTool(  
src/mcp/server.ts:135 — server.registerTool(
```

Bien

Sin permisos de agente demasiado amplios

★★★★★

100%

0 autoaprobaciones, consejos de «saltar permisos» o instalaciones curl | sh.

Qué hacer: Nunca recomiendes saltar permisos; ofrece configuraciones acotadas e instaladores firmados.

Bien

La salida del modelo se valida

★★★★☆

80%

5 archivos llaman a un LLM; 2 validan la respuesta con un esquema.

Qué hacer: Trata el contenido web como datos: valida cada respuesta del modelo con un esquema antes de actuar.

Evidencia

```
src/cli/main.ts — calls an LLM API  
src/mcp/server.ts — calls an LLM API  
src/auditors/llm-auditor.ts — model output schema-validated  
src/simulator/llm-policy.ts — model output schema-validated
```

Bien

Ejecución de shell limitada

★★★★☆

76%

3 lugares ejecutan comandos de shell.

Qué hacer: Evita shell:true; pasa argumentos como lista y nunca interpoles datos del usuario.

Evidencia

```
scripts/secret-scan.mjs:15 — const files = execSync('git ls-files --cached --  
others --exclude-standard', { encoding: 'utf8' })  
src/engines/external.ts:60 — const child = spawn(o.command, { shell: true, stdio:  
['pipe', 'pipe', 'pipe'] });  
src/panels/developers.ts:47 — shell: true,
```

Mejorar

Superficie web (Argus)

★★★★☆

71%

Comprobaciones pasivas de Argus en el sitio público: 9 hallazgos.

Qué hacer: Añade cabeceras de seguridad, redirecciones HTTPS y páginas de privacidad accesibles.

Evidencia

`argus:headers.clickjacking-protection-not-observed` — review · No framing protection was observed (X-Frame-Options or CSP frame-ancestors)

`argus:privacy.no-privacy-link` — review · No privacy-policy link was found in the delivered homepage HTML

`argus:transport.hsts-not-observed` — review · Strict-Transport-Security header was not observed

`argus:transport.no-https-redirect` — review · Plain HTTP was answered without redirecting to HTTPS

`argus:a11y.html-lang-not-observed` — informational · The page did not declare a language

`argus:headers.permissions-policy-not-observed` — informational · Permissions-Policy header was not observed

`argus:headers.referrer-policy-not-observed` — informational · Referrer-Policy header was not observed

`argus:headers.x-content-type-options-not-observed` — informational · X-Content-Type-Options header was not observed

Bien

Privacidad: cookies y terceros



100%

0 servidores de terceros llamados y 0 cookies creadas durante los recorridos.

Qué hacer: Quita llamadas a terceros innecesarias y crea cookies solo tras el consentimiento.

Evidencia

`cookies` — 0 cookies, 0 without Secure/HttpOnly

Segmentos

¿Funciona para todo el mundo, no solo para la visita media?

91/100



15 % de la ejecución · 6 revisores sintéticos

Puntuación por segmento

Accesibilidad		66%
Conexión lenta		100%
No quiere crear cuenta		100%
Zoom al 200 % y pantallas p...		100%
Otros idiomas		100%
Móvil		100%

Comprobaciones

Accesibilidad		66%
Funciona con conexión lenta		100%
Funciona sin crear cuenta		100%
Zoom al 200 % y pantallas p...		100%
Otros idiomas		100%
Igualdad en el móvil		100%

6 revisores sintéticos

Accesibilidad		66%
Conexión lenta		100%
No quiere crear cuenta		100%
Zoom al 200 % y pantallas p...		100%
Otros idiomas		100%
Móvil		100%

Mejorar

Accesibilidad

★★★★★

66%

1 páginas revisadas: etiquetas, texto alternativo, nombres de controles, tamaño táctil, contraste e idioma.

Qué hacer: Etiqueta cada campo, añade texto alternativo, agranda los objetivos pequeños y corrige el contraste.

Evidencia

<https://abrahamhl.github.io/buyer-arena-site/es/> — unlabeled 0 · no-alt 0 · unnamed 0 · small 4 · contrast 19

https://abrahamhl.github.io/buyer-arena-site/es/#small_target — <a href="https://github.com/abrahamhl/buyer-arena" rel="noopener" data-ba-idx="2

Bien

Funciona con conexión lenta

★★★★★

100%

Con una conexión móvil lenta, el 100% alcanzó el objetivo; carga mediana 0 ms.

Qué hacer: Reduce el peso de la página y muestra la acción principal antes que nada.

Evidencia

[current-p-001:e0](#) — completed · 1 steps

[current-p-002:e0](#) — completed · 1 steps

[current-p-003:e0](#) — completed · 1 steps

Bien

Funciona sin crear cuenta

★★★★★

100%

El 100% de quienes no quieren crear cuenta alcanzó igualmente el objetivo.

Qué hacer: Ofrece un camino de invitado o un inicio sin contraseña (enlace mágico, prueba sin registro).

Bien

Zoom al 200 % y pantallas pequeñas

★★★★★

100%

Desbordamiento horizontal con zoom al 200 % / 320 px: 0/0 px.

Qué hacer: Deja que el contenido se reacomode; nada de anchos fijos mayores que la pantalla.

Evidencia

<https://abrahamhl.github.io/buyer-arena-site/es/> @zoom200 — horizontal overflow 0px

<https://abrahamhl.github.io/buyer-arena-site/es/> @phone320 — horizontal overflow 0px

Bien

Otros idiomas

★★★★★

100%

Idioma de la página «es»; 4 enlaces a otros idiomas.

Qué hacer: Declara el idioma de la página y ofrece páginas traducidas con hreflang.

Evidencia

<https://abrahamhl.github.io/buyer-arena-site/es/> — lang="es" · 4 hreflang alternates

Bien

Igualdad en el móvil

★★★★★ 100%

Objetivo alcanzado: móvil 100%, ordenador 100%.

Qué hacer: Prueba el camino completo en un móvil: menús, pop-ups y formularios.

Evidencia

[current-p-004:e0](#) — completed

[current-p-009:e0](#) — completed

[current-p-014:e0](#) — completed

Plan de acción

Cada comprobación floja de cada panel, ordenada por su margen × peso × la atención que diste a ese panel.

1 Evidencia de adopción

Consigue usuarios reales antes de buscar inversión: publica una versión, lista quién lo usa y reúne dos o tres testimonios.

Inversores · puntuación 5 · impacto 57

2 Accesibilidad

Etiqueta cada campo, añade texto alternativo, agranda los objetivos pequeños y corrige el contraste.

Segmentos · puntuación 66 · impacto 20

3 Superficie web (Argus)

Añade cabeceras de seguridad, redirecciones HTTPS y páginas de privacidad accesibles.

Equipo rojo · puntuación 71 · impacto 13

